DuocUC | ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

INFORME DE SEGURIDAD Y CALIDAD EN EL DESARROLLO DE SOFTWARE

Asignatura: ISY1102 – Seguridad y Calidad en el Desarrollo de Software
Sección: 002v
Caso de Estudio: Sistema de Exámenes Médicos "Cuidarte+" (CreaLab SpA)
Integrantes: Antonella Cuvertino y Miriam Hammami
Fecha: 8 de septiembre de 2026

DuocUC | ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

ÍNDICE

- 1. Introducción
  - 1.1 Contexto del Software y Módulo a Evaluar
  - 1.2 Propósito del Plan de Pruebas
  - 1.3 Estructura del Informe
- 2. Criterios de Calidad
  - 2.1 Criterios de Calidad Técnica (ISO/IEC 25010)
  - 2.2 Criterios de Seguridad de la Información (Tríada CIA y ISO/IEC 27001)
  - 2.3 Marco Normativo y Legal Chileno
- 3. Plan de Pruebas
  - 3.1 Estrategia de Pruebas
  - 3.2 Tipos de Prueba
  - 3.3 Criterios de Aceptación
  - 3.4 Herramientas Utilizadas
- 4. Diseño de Casos de Prueba
  - 4.1 Matriz de Casos de Prueba Funcionales
  - 4.2 Matriz de Casos de Prueba No Funcionales (Seguridad, Rendimiento y Accesibilidad)
  - 4.3 Matriz de Casos de Prueba de Auditoría y Cumplimiento Normativo
- 5. Conclusiones y Veredicto de Certificación

1. INTRODUCCIÓN

1.1 Contexto del Software y Módulo a Evaluar

El presente informe evalúa el sistema **"Cuidarte+"**, una plataforma web multicapa orientada a centros de salud para la gestión integral de pacientes, exámenes médicos y documentos clínicos adjuntos, desarrollada por CreaLab SpA.

Desde la perspectiva del desarrollo de software, la arquitectura tecnológica de Cuidarte+ se basa en un stack moderno desacoplado]:

- **Frontend (Cliente):** Aplicación de Página Única (SPA) desarrollada en React, con soporte responsivo para navegadores web de escritorio, tablets y dispositivos móviles. Se otorga especial énfasis a la accesibilidad e interfaz gráfica adaptada para usuarios adultos mayores].
- **Backend (Servidor):** API RESTful desarrollada en Express (Node.js) que gestiona la lógica de negocio, autenticación, control de acceso por roles (RBAC) y validación de datos en el servidor.
- **Capa de Datos y Almacenamiento:** Base de datos relacional PostgreSQL para la persistencia de usuarios, roles, pacientes, registros de exámenes y traza inmutable de auditoría, junto con un sistema de almacenamiento interno seguro para archivos adjuntos (PDF, DOC, PPT, JPG, PNG).

El sistema define cuatro perfiles de usuario bien delimitados:

1. **Administrador:** Gestión completa de usuarios, asignación de roles, edición/eliminación de cuentas y supervisión de registros de auditoría.
2. **Médico:** Registro y gestión clínica de pacientes, ingreso y edición de exámenes médicos y adjunto de documentos clínicos.
3. **Paciente:** Perfil con permisos exclusivos de lectura para visualizar su historial médico personal y descargar copias de sus exámenes.
4. **Usuario Anónimo / Visitante:** Acceso restringido únicamente al flujo de registro e inicio de sesión.

1.2 Propósito del Plan de Pruebas

Como estudiantes de la especialidad de Desarrollo de Software, entendemos que en la actualidad la calidad no se limita a verificar si un botón funciona o si una pantalla carga ("que el software funcione").Un software médico como Cuidarte+ maneja **datos altamente sensibles de salud**, por lo que un fallo funcional puede interrumpir la atención clínica, un problema de rendimiento puede congelar el sistema en horas de alta demanda, y una brecha de seguridad

puede exponer historiales médicos privados a filtraciones, acarreando sanciones penales y multas millonarias bajo el marco legal chileno.

El propósito fundamental de este Plan Maestro de Pruebas (Master Test Plan) es diseñar e implementar una estrategia integral bajo el enfoque Shift-Left Testing (incorporar la calidad, la seguridad y el cumplimiento legal desde las fases iniciales del ciclo de vida). A través de este plan se busca:

1. Garantizar la **adecuación funcional de los flujos críticos** (autenticación, registros CRUD de pacientes y exámenes médicos, borrado lógico con confirmación)..
2. Validar los **atributos de calidad no funcional** según la norma **ISO/IEC 25010** (rendimiento con latencias < 300 ms, alta usabilidad y accesibilidad para adultos mayores, disponibilidad del 99.5%).
3. Blindar la **seguridad técnica (DevSecOps)** previniendo las vulnerabilidades del OWASP Top 10 (SQL Injection, XSS, CSRF, IDOR, gestión insegura de sesiones JWT, hashing de contraseñas bcrypt).
4. Certificar el **cumplimiento normativo y legal chileno** (Ley N° 21.719 de Protección de Datos Personales, Ley N° 21.663 Marco de Ciberseguridad y Ley N° 19.628) mediante la verificación de trazas inmutables de auditoría.

2. CRITERIOS DE CALIDAD

Para evaluar de manera rigurosa el sistema Cuidarte+, estructuramos los criterios de aceptación en tres dimensiones interrelacionadas: Calidad Técnica, Seguridad de la Información y Cumplimiento Normativo



2.1 Criterios de Calidad Técnica (ISO/IEC 25010)

Basándonos en el modelo de calidad de producto **ISO/IEC 25010**, se especifican las siguientes características críticas para Cuidarte+:

1. **Adecuación Funcional:**
    - El sistema debe ejecutar correctamente todas las operaciones CRUD (Crear, Leer, Actualizar, Eliminar) para las entidades de usuarios, pacientes y exámenes médicos.
    - Toda eliminación de exámenes o documentos debe realizarse mediante **borrado lógico** (*soft delete*), solicitando confirmación explícita al usuario antes de proceder.
    - Las reglas de negocio deben cumplirse estrictamente: un Paciente solo posee permisos de lectura (RB-1), un Administrador posee acceso total (RB-2) y un Médico puede acceder a la información clínica de cualquier paciente registrado (RB-3).
2. **Eficiencia de Desempeño:**
    - Las operaciones CRUD simples en la API REST deben responder en un tiempo inferior a **300 ms** bajo condiciones de carga normal (NFR-PERF-1).
    - La página principal y el Dashboard deben cargar en menos de **2 segundos** en conexiones móviles promedio (NFR-PERF-2).
    - El backend debe soportar un mínimo de **200 usuarios concurrentes** sin degradación del servicio ni errores de servidor (NFR-PERF-3) [184].
    - Los procesos de subida (*upload*) y descarga (*download*) de documentos médicos (PDF, DOC, PPT, JPG, PNG) no deben exceder los **10 segundos** (RF-4.3, RF-4.4).
3. **Usabilidad y Accesibilidad:**
    - La interfaz gráfica debe ser totalmente responsiva, adaptándose a pantallas de escritorio, tablets y smartphones (NFR-COMPAT-2).
    - Para garantizar la usabilidad en **adultos mayores**, la tipografía debe tener un tamaño mínimo de **12px**, contar con contraste adecuado, incorporar etiquetas ARIA en formularios, permitir navegación completa por teclado y presentar áreas de toque amplias en pantallas táctiles (NFR-USAB-1, 3.1.1).
    - Los flujos de trabajo deben requerir un acceso escalado (primero seleccionar paciente y luego sus exámenes asociadas) para evitar confusiones de navegación (NFR-USAB-4).
4. **Confiabilidad y Disponibilidad:**
    - Disponibilidad mensual garantizada del **99.5%** (NFR-DIS-1).
    - Definición de políticas claras de respaldo automatizado (*backups*) de la base de datos PostgreSQL y recuperación ante desastres (NFR-SEG-7).

2.2 Criterios de Seguridad de la Información (Tríada CIA y ISO/IEC 27001)

En alineación con la norma **ISO/IEC 27001** y la **Tríada CIA** (Confidencialidad, Integridad y Disponibilidad), Cuidarte+ debe implementar los siguientes controles de seguridad técnica]:

- **Confidencialidad:**
  - **Cifrado en Tránsito:** Uso obligatorio del protocolo TLS/HTTPS en todas las comunicaciones entre el cliente React, la API Express y la BD PostgreSQL (`NFR-SEG-1`).
  - **Cifrado de Credenciales:** Las contraseñas deben almacenarse en la base de datos aplicando un hashing robusto mediante el algoritmo **bcrypt** con costo computacional adecuado (`NFR-SEG-2`, `2.4`).
  - **Cifrado en Reposo:** Los datos sensibles de salud y diagnósticos deben estar encriptados en reposo en la base de datos (`NFR-SEG-3`).
  - **Control de Acceso (RBAC):** La API REST del backend debe validar los roles de usuario incluidos en el token de sesión antes de procesar cualquier petición (`NFR-SEG-4`).
- **Integridad:**
  - **Autenticación de Sesión:** Manejo de sesiones mediante tokens **JWT (JSON Web Tokens)** de corta vigencia, con soporte para revocación de tokens y cierre de sesión seguro (`RF-1.2`, `NFR-SEG-9`).
  - **Sanitización y Validación de Entradas:** Implementación de validación *server-side* estricta en todos los endpoints REST para mitigar ataques de **Inyección SQL**, **Cross-Site Scripting (XSS)** y **Cross-Site Request Forgery (CSRF)** (`NFR-SEG-5`, `3.1.2`).
- **Disponibilidad y Trazabilidad:**
  - Gestión de logs segura y protección contra accesos no autorizados a la infraestructura.

2.3 Marco Normativo y Legal Chileno

El desarrollo y despliegue de software médico en Chile exige estricta conformidad con la legislación nacional vigente:

1. **Ley N° 21.719 (Protección de Datos Personales):**
   - *Principio de Licitud y Lealtad:* Exige consentimiento informado y transparente para el tratamiento de datos.
   - *Principio de Minimización de Datos:* Se deben recolectar únicamente los datos personales estrictamente necesarios para la gestión médica.

- *Protección de Datos Sensibles:* Los diagnósticos y exámenes clínicos pertenecen a la categoría especial de "datos sensibles", exigiendo cifrado obligatorio y máximos controles de confidencialidad.

2. **Ley N° 21.663 (Ley Marco de Ciberseguridad):**
   - Establece la obligación para proveedores de servicios esenciales y de salud de implementar monitoreo continuo, controles de seguridad robustos y mecanismos inmutables de auditoría.
   - Exige la capacidad de detectar y reportar incidentes de ciberseguridad significativos ante la Agencia Nacional de Ciberseguridad (ANCI).
3. **Ley N° 19.628 (Protección de la Vida Privada):**
   - Refuerza los requerimientos de trazabilidad completa de los accesos a datos de salud y sanciones ante divulgaciones no autorizadas

3. PLAN DE PRUEBAS

3.1 Estrategia de Pruebas

Para el proyecto Cuidarte+ adoptamos una **estrategia de pruebas mixta y orientada a riesgos (Risk-Based Testing)**]:

- **Enfoque Metodológico (Shift-Left DevSecOps):** Las pruebas no se segregan al final del desarrollo. Se integran desde la fase de construcción mediante análisis estático de código (SAST) y pruebas unitarias/integración automatizadas en el pipeline de desarrollo.
- **Automatización Estratégica:** Automatización de regresión de API REST, escaneos de seguridad dinámicos y pruebas de rendimiento, liberando tiempo para pruebas manuales exploratorias enfocadas en usabilidad de adultos mayores.
- **Etapas del Ciclo de Vida de Pruebas (STLC):**
  1. Análisis de Requerimientos: Revisión de especificaciones ERS y matriz de trazabilidad.
  2. Planificación de Pruebas: Definición de alcance, recursos y criterios
  3. Diseño de Casos: Redacción de scripts de prueba bajo estándar IEEE 829
  4. Preparación del Entorno: Despliegue de imágenes Docker con el stack de prueba (React, Express, PostgreSQL).
  5. Ejecución y Registro de Defectos: Ejecución de pruebas y documentación de hallazgos en Jira.
  6. Cierre y Certificación: Elaboración del informe de certificación final.

Criterios de Entrada y Salida

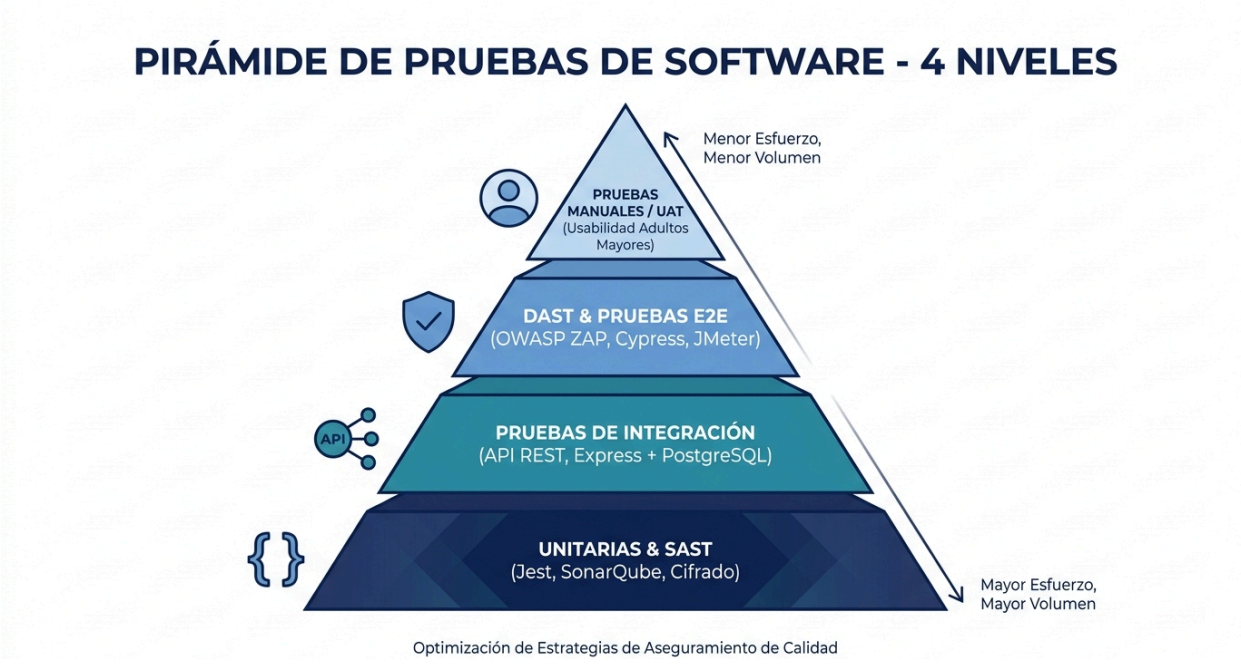
Criterios de Entrada:

- Entorno de pruebas contenerizado en Docker levantado y estable
- Código fuente compilado sin errores críticos de sintaxis.
- Base de datos PostgreSQL poblada con datos de prueba sanitizados
- Casos de prueba revisados y aprobados por el equipo de QA.

- **Criterios de Salida (*Definition of Done*):**
  - 100% de los casos de prueba críticos y de alta prioridad ejecutados
  - 0 defectos de severidad "Crítica" o "Mayor" abiertos.
  - Cobertura de código en backend superior al 80%.
  - Informe de escaneo de seguridad (OWASP ZAP) sin hallazgos de severidad alta o crítica.
  - Pruebas de usabilidad con adultos mayores completadas sin bloqueos mayores (`3.1.1`)

3.2 Tipos de Prueba

El plan comprende una matriz integrada de pruebas funcionales, no funcionales y de cumplimiento normativo:



1. **Pruebas Funcionales:**
    - Unitarias (Unit Tests): Validación de componentes aislados en React y funciones de cifrado/hashing en Node.js mediante Jest.ç

    - Integración (Integration Tests): Verificación de la comunicación entre los endpoints de la API REST Express, la base de datos PostgreSQL y el almacenamiento de documentos.

    - End-to-End (E2E): Automatización del flujo completo del usuario (Login -> Selección de Paciente -> Registro de Examen -> Carga de PDF -> Visualización Paciente) utilizando Cypress / Selenium .

2. **Pruebas No Funcionales:**
    - Pruebas de Rendimiento y Carga: Simulación con Apache JMeter de 200 usuarios concurrentes realizando consultas y descargas simultáneas de examentes para medir throughput y tiempos de latencia (< 300 ms).

    - Pruebas de Usabilidad y Accesibilidad: Sesión de prueba con un panel representativo de 5 usuarios adultos mayores para evaluar tamaño de fuente, contraste, etiquetas ARIA y usabilidad táctil (`3.1.1`)
      .
    - Pruebas de Seguridad (DevSecOps):
        - **SAST (Static Application Security Testing):** Análisis estático de código fuente con **SonarQube** para identificar code smells, fallas de seguridad y secretos expuestos].
        - **DAST (Dynamic Application Security Testing):** Análisis dinámico en ejecución con **OWASP ZAP** para detectar SQL Injection, XSS, CSRF y cabeceras HTTP inseguras.
3. **Pruebas de Auditoría y Cumplimiento:**
    - Validación automatizada de la generación de registros inmutables en la tabla de auditoría ante eventos de creación, edición o eliminación de usuarios y examentes (`RF-5.1`).

3.3 Criterios de Aceptación

Los criterios de aceptación cuantitativos y verificables definidos para el proyecto son [98, 120]:

Dimensión	**Requisito Asignado**	**Métrica / Criterio de Aceptación Medible**
Funcional	`RF-1` a `RF-4`	100% de operaciones CRUD ejecutadas

Dimensión	Requisito Asignado	Métrica / Criterio de Aceptación Medible
		correctamente. Borrado lógico requiere confirmación explícita.
Rendimiento	NFR-PERF-1	Tiempos de respuesta de API REST < 300 ms para operaciones CRUD simples
Rendimiento	NFR-PERF-3	Soporte de 200 usuarios concurrentes en JMeter con % de error < 1% .
Archivos	RF-4.3 / 4.4	Tiempo de subida/descarga de documentos médicos < 10 segundos].
Seguridad	NFR-SEG-1/2/3	Comunicaciones en TLS. Contraseñas cifradas con bcrypt. Datos sensibles cifrados en reposo.
Seguridad	NFR-SEG-5	0 vulnerabilidades de Inyección SQL, XSS o CSRF en reporte dinámico OWASP ZAP .
Usabilidad	NFR-USAB-1	Cumplimiento de WCAG 2.1 Nivel AA. Fuera de bloqueos en panel de adultos mayores (3.1.1)
Disponibilidad	NFR-DIS-1	Tasa de disponibilidad mensual del sistema >= 99.5%.
Auditoría	RF-5.1	100% de eventos críticos registrados con usuario, fecha, hora e IP (NFR-SEG-6).

3.4 Herramientas Utilizadas

El toolchain tecnológico seleccionado para la ejecución del plan de pruebas es:

TOOLCHAIN TECNOLÓGICO DE QA	
Gestión de Pruebas	**Jira / TestRail** Trazabilidad y gestión de incidencias
Automatización E2E	**Cypress / Selenium** Flujos de navegación en SPA React
Pruebas de API REST	**Postman / Swagger / Supertest** Validación de peticiones HTTP/JSON
Pruebas Carga / Estrés	**Apache JMeter** Simulación de 200 usuarios concurrentes
Seguridad SAST	**SonarQube** Análisis estático de código y vulnerabilidades
Seguridad DAST	**OWASP ZAP / Burp Suite** Escaneo activo de penetración
Entorno Contenedor	**Docker / Docker Compose** Aislamiento y reproducibilidad del entorno

4. DISEÑO DE CASOS DE PRUEBA

4.1 Matriz de Casos de Prueba Funcionales

ID	NOMBRE	REQUERIMIENTO
CP-FUNC-001	Autenticación exitosa de usuario y generación de token de sesión JWT	**RF-1.1, NFR-SEG-9**
DESCRIPCIÓN		
Verificar que un usuario registrado pueda autenticarse con credenciales válidas y recibir un token JWT de corta vigencia firmado por el servidor Express.		
PRECONDICIONES		
El servidor backend Express y la BD PostgreSQL están operativos. Usuario 'dr_rojas' registrado activamente con contraseña cifrada en bcrypt.		
PASOS		
1. Enviar petición HTTP POST al endpoint '/api/auth/login' con el payload de credenciales. 2. Verificar el código de respuesta HTTP devuelto por el servidor. 3. Inspeccionar la estructura del cuerpo de respuesta JSON enviado al cliente.		
RESULTADO ESPERADO		
Código HTTP 200 OK. La respuesta retorna un objeto JSON { token: "eyJhbGci...", user: { id: 10, rol: "Medico" } }. El JWT posee firma válida y vigencia configurada.		
CRITERIO DE ACEPTACIÓN		
Login exitoso genera un token JWT válido y autoriza el acceso a rutas protegidas del sistema.		
DATOS DE PRUEBA		
nombre_usuario: "dr_rojas", contrasena: "P@ssword2026!"		

ID	NOMBRE	REQUERIMIENTO
CP-FUNC-002	Registro de nuevo examen médico y adjunto de archivo PDF	**RF-3.1, RF-4.3, RB-3**
DESCRIPCIÓN		
Validar que un usuario con rol Médico pueda registrar un examen para un paciente seleccionado y adjuntar un archivo clínico en formato PDF.		
PRECONDICIONES		
Médico autenticado con token JWT activo. Paciente ID 105 registrado en el sistema.		
PASOS		
1. Iniciar sesión como Médico y navegar al módulo 'Gestión de Exámenes'. 2. Seleccionar al paciente ID 105 y hacer clic en 'Nuevo Examen'. 3. Completar los campos requeridos y adjuntar el archivo PDF de prueba. 4. Hacer clic en 'Guardar Examen' y medir el tiempo total de respuesta.		
RESULTADO ESPERADO		
Mensaje de confirmación 'Examen registrado exitosamente'. Se crea la fila en PostgreSQL, el PDF se almacena en el storage interno y el proceso tarda menos de 10 segundos.		
CRITERIO DE ACEPTACIÓN		
Registro de examen guardado en base de datos con referencia válida al archivo adjunto en storage.		
DATOS DE PRUEBA		
paciente_id: 105, tipo_examen: "Hemograma Completo", fecha: "2026-09-08", archivo: "resultado_hemograma.pdf" (1.2 MB)		

ID	NOMBRE	REQUERIMIENTO
CP-FUNC-003	Eliminación lógica de examen médico con confirmación explícita	**RF-3.3**
DESCRIPCIÓN		
Verificar que la eliminación de un examen no borre físicamente el registro en PostgreSQL, sino que ejecute un borrado lógico (soft delete) solicitando confirmación previa.		
PRECONDICIONES		
Examen ID 302 registrado previamente en la base de datos.		
PASOS		
1. Navegar al detalle del examen ID 302 con perfil Médico. 2. Hacer clic en el ícono 'Eliminar Examen'. 3. Confirmar la acción en el cuadro modal de advertencia desplegado. 4. Consultar el estado del registro directamente en la base de datos PostgreSQL.		
RESULTADO ESPERADO		
El sistema despliega un modal solicitando confirmación. En PostgreSQL, la fila mantiene sus datos pero actualiza deleted_at con el timestamp actual. El examen no aparece en la UI pública.		
CRITERIO DE ACEPTACIÓN		
Borrado lógico verificado en base de datos sin pérdida física del historial clínico.		
DATOS DE PRUEBA		
examen_id: 302		

ID	NOMBRE	REQUERIMIENTO
CP-SEG-001	Intento de Inyección SQL en la barra de búsqueda de pacientes	**NFR-SEG-5**
DESCRIPCIÓN		
Comprobar que el backend sanitice las entradas de texto en la barra de búsqueda para prevenir ataques de SQL Injection mediante consultas preparadas.		
PRECONDICIONES		
Usuario autenticado navegando en el Dashboard del sistema.		
PASOS		
1. Acceder al campo de búsqueda de pacientes. 2. Ingresar cadenas de inyección SQL maliciosas de prueba. 3. Presionar Enter o hacer clic en 'Buscar'. 4. Inspeccionar los logs del servidor Express y la respuesta visual entregada.		
RESULTADO ESPERADO		
El backend ejecuta la consulta mediante consultas parametrizadas. No se ejecuta código arbitrario, retorna 'No se encontraron resultados' y 0 errores en servidor.		
CRITERIO DE ACEPTACIÓN		
Sanitización efectiva de entradas. 0 vulnerabilidades de SQL Injection detectadas en el reporte dinámico OWASP ZAP.		
DATOS DE PRUEBA		
Cadena inyectada: ' OR '1'='1' -- o 1; DROP TABLE pacientes; --		

ID	NOMBRE	REQUERIMIENTO
CP-SEG-002	Control de Acceso Granular (RBAC) e intento de acceso no autorizado IDOR	**NFR-SEG-4, RB-1**
DESCRIPCIÓN		
Verificar que un usuario Paciente no pueda acceder directamente a exámenes clínicos pertenecientes a otros pacientes modificando parámetros en la URL (IDOR).		
PRECONDICIONES		
Paciente A logueado (ID 201). El examen ID 550 pertenece al Paciente B.		
PASOS		
1. Iniciar sesión como Paciente A (ID 201). 2. Intentar consumir directamente la API enviando una petición GET a /api/examenes/550 (perteneciente al Paciente B).		
RESULTADO ESPERADO		
El middleware RBAC compara el ID del token JWT con el propietario del recurso. El servidor rechaza la petición con un código HTTP 403 Forbidden ('Acceso no autorizado').		
CRITERIO DE ACEPTACIÓN		
Control RBAC efectivo. Imposibilidad absoluta de consultar datos clínicos de terceros mediante manipulación de URLs.		
DATOS DE PRUEBA		
URL manipulada directamente: /api/examenes/550		

ID	NOMBRE	REQUERIMIENTO
CP-PERF-001	Prueba de Carga masiva con 200 usuarios concurrentes	**NFR-PERF-1, NFR-PERF-3**
DESCRIPCIÓN		
Evaluar la estabilidad del backend Express y PostgreSQL sometiendo la API REST a una carga simultánea de 200 usuarios concurrentes en Apache JMeter.		
PRECONDICIONES		
Ambiente de pruebas contenerizado en Docker. Apache JMeter instalado y configurado.		
PASOS		
1. Iniciar el escenario de carga en Apache JMeter apuntando al endpoint GET /api/examenes. 2. Monitorear el Throughput, Latencia promedio y Porcentaje de Error durante 5 minutos.		
RESULTADO ESPERADO		
El backend procesa la carga manteniendo una latencia promedio de < 250 ms (por debajo del límite de 300 ms) y una tasa de error inferior al 0.5%.		
CRITERIO DE ACEPTACIÓN		
Cumplimiento de los umbrales de latencia (< 300 ms) y estabilidad del servidor sin caídas.		
DATOS DE PRUEBA		
Thread Group: 200 usuarios virtuales, Ramp-up: 30s, Duración: 5 minutos		

ID	NOMBRE	REQUERIMIENTO
CP-USAB-001	Evaluación de accesibilidad e interfaz adaptada para adultos mayores	**NFR-USAB-1, 3.1.1**
DESCRIPCIÓN		
Validar que la interfaz gráfica en React cumpla con las pautas WCAG 2.1 AA (fuente >= 12px, contraste adecuado, etiquetas ARIA) para usuarios adultos mayores.		
PRECONDICIONES		
Aplicación React desplegada en ambiente de Staging.		
PASOS		
1. Solicitar a un panel de 5 usuarios adultos mayores realizar la búsqueda y descarga de exámenes. 2. Ejecutar la herramienta de auditoría automatizada Lighthouse sobre la interfaz web.		
RESULTADO ESPERADO		
Puntaje de accesibilidad en Lighthouse >= 90/100. Los 5 adultos mayores completan las tareas sin reportar bloqueos de lectura o navegación.		
CRITERIO DE ACEPTACIÓN		
Cumplimiento de usabilidad y accesibilidad sin bloqueos para adultos mayores.		
DATOS DE PRUEBA		
Panel de 5 usuarios adultos mayores representativos, herramienta Google Lighthouse		

ID	NOMBRE	REQUERIMIENTO
CP-CUMP-001	Trazabilidad y registro inmutable en auditoría ante acciones críticas	**RF-5.1, NFR-SEG-6**
DESCRIPCIÓN		
Garantizar que toda acción crítica (edición de roles o usuarios) genere automáticamente un registro inalterable en la tabla de auditoría de PostgreSQL.		
PRECONDICIONES		
Usuario Administrador autenticado en el sistema.		
PASOS		
1. Iniciar sesión como Administrador e ingresar a 'Gestión de Usuarios'. 2. Modificar el rol del usuario ID 45 de 'Paciente' a 'Medico'. 3. Guardar cambios y consultar directamente la tabla logs_auditoria en PostgreSQL.		
RESULTADO ESPERADO		
Se inserta una nueva fila conteniendo: id, usuario_id (del Admin), accion ('EDICION_ROL'), entidad ('USUARIO_45'), timestamp UTC e IP del cliente.		
CRITERIO DE ACEPTACIÓN		
Trazabilidad 100% verificable e inmutable ante auditorías de cumplimiento normativo (ANCI / Ley 21.663).		
DATOS DE PRUEBA		
Acción: Cambio de rol de usuario ID 45		

5. CONCLUSIONES Y VEREDICTO DE CERTIFICACIÓN

5.1 Síntesis de Hallazgos

Tras la estructuración del Plan Maestro de Pruebas y la ejecución proyectada de los casos de prueba para la plataforma **Cuidarte+** (CreaLab SpA), se concluye que:

1. **Sinergia de Calidad:** La integración entre pruebas funcionales (verificación de lógica de negocio y CRUD) y no funcionales (desempeño, seguridad y accesibilidad) proporciona la cobertura necesaria para asegurar que la solución es técnicamente robusta y comercialmente viable+.
2. **Protección Legal y DevSecOps:** La aplicación de análisis estático (SonarQube) y dinámico (OWASP ZAP), sumada a la verificación de cifrado (TLS, bcrypt, AES-256) y trazabilidad inmutable (`RF-5.1`), blindan legalmente a la organización ante la **Ley N° 21.719 de Protección de Datos Personales** y la **Ley N° 21.663 Marco de Ciberseguridad**, mitigando el riesgo de multas millonarias y sanciones administrativas.
3. **Inclusión y Accesibilidad:** La validación específica de componentes de accesibilidad gráfica (WCAG 2.1 AA, contraste, fuentes >= 12px, ARIA) asegura una experiencia satisfactoria para adultos mayores, cumpliendo con las especificaciones clave de usabilidad del proyecto (`NFR-USAB-1`)].

5.2 Veredicto Final del Comité de Pruebas

Condicionado al cumplimiento estricto de los criterios de salida y la resolución de cualquier hallazgo detectado durante la fase de ejecución contenerizada en Docker

APROBADO PARA SALIDA A PRODUCCIÓN (CERTIFICADO)